DOCUMENT CONTROL PAGE

Field	Details
Document Title	Identity and Access Management Policy
Document ID	CIL-GRC-IAM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5(Organizational Controls)
Control Reference/Sub-Domain	5.16, 5.17
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer(s)	IAM Specialist, Legal & Compliance Officer
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____

For: Cyberinfiniti Ltd

IDENTITY & ACCESS MANAGEMENT (IAM) POLICY SUMMARY

1. Purpose

This policy establishes governance for the full lifecycle of identities and authentication information within CyberInfiniti Ltd. It ensures that all users and systems are uniquely identified, access rights are appropriately assigned and revoked, and authentication mechanisms are securely managed.

The policy supports protection of information assets, accountability of user activities, and compliance with **ISO/IEC 27002:2022** and the **Nigeria Data Protection Act 2023**, as well as contractual obligations.

2. Organisational Context

CyberInfiniti Ltd operates as a cybersecurity and compliance firm handling sensitive client data, vulnerability findings, and regulatory documentation. Effective Identity and Access Management (IAM) is critical to:

- Prevent unauthorized access to systems and data
- Maintain accountability and traceability of user actions
- Protect the confidentiality, integrity, and availability of information assets

IAM forms a foundational control within the organization's overall security and governance framework.

3. Scope

This policy applies to:

- All employees, contractors, and consultants
- All third-party service providers accessing CyberInfiniti systems
- All identities (human and non-human, including service accounts)
- All forms of authentication information (passwords, PINs, tokens, certificates)

It covers all systems, applications, cloud environments, and platforms managed or operated by the organization.

4. IAM Framework Definition

Identity and Access Management (IAM) is the structured framework governing how identities are created, managed, authenticated, and authorized.

It ensures:

- **Unique Identification:** Every entity has a distinct identity

- **Access Control:** Access is granted based on business need and authorization
- **Lifecycle Management:** Identities are created, updated, and removed in a controlled manner
- **Authentication Security:** Credentials are securely issued and managed
- **CIA Protection:** Confidentiality, integrity, and availability are maintained

5. IAM Objectives

CyberInfiniti Ltd aims to:

- Ensure unique and accountable identities
- Enforce least privilege and role-based access
- Manage identity lifecycle efficiently
- Protect authentication information from compromise
- Maintain audit trails for accountability and investigations
- Achieve regulatory and ISO compliance
- Continuously improve IAM controls against evolving threats

6. Policy Statements

Aligned with ISO/IEC 27002:2022 controls **5.16 (Identity Management)** and **5.17 (Authentication Information)**:

6.1 Governance

Management shall provide oversight, resources, and accountability for IAM implementation and enforcement.

6.2 Identity Lifecycle Management

- All identities must be unique and traceable
- Shared accounts are prohibited unless formally approved
- Non-human identities require controlled ownership and monitoring
- Access must be revoked immediately upon role change or exit

6.3 Authentication Security

- Credentials must be securely generated, transmitted, and stored
- Default credentials must be changed immediately
- Temporary credentials must be changed at first use
- Strong authentication (e.g., MFA) must be enforced

6.4 Access Control

- Access rights must follow least privilege and role-based principles
- Access must be formally approved and periodically reviewed

6.5 Compliance

IAM practices must align with regulatory, contractual, and ISO requirements.

6.6 Auditability

All identity and authentication activities must be logged and retained for monitoring, investigation, and audit purposes.

6.7 Continual Improvement

IAM controls shall be continuously improved based on audits, incidents, risk assessments, and regulatory changes.

6.8 Exception Management

Exceptions must be risk-assessed, documented, approved by the CISO, and periodically reviewed.

7. Roles & Responsibilities

Key responsibilities include:

- **Managing Director:** Executive oversight and policy approval
- **CISO:** Policy ownership, strategy, and compliance assurance
- **GRC Manager:** Policy development, monitoring, and audit coordination
- **SOC Manager:** Operational enforcement and incident monitoring
- **IAM Specialist:** Identity lifecycle and access management
- **IT Operations Lead:** Authentication systems and privileged access control
- **System Owners:** Access approval and periodic validation
- **All Employees:** Compliance and protection of credentials
- **Third Parties:** Adherence to IAM requirements

8. Monitoring, Compliance & Enforcement

Compliance is ensured through:

- Periodic access reviews and privilege validation
- Monitoring of privileged and high-risk accounts
- Authentication and credential audits

- Identity lifecycle audits
- Incident tracking (e.g., unauthorized access, credential compromise)
- Risk assessments and executive reporting

Non-compliance may result in disciplinary action, contract termination, or legal consequences.

9. Communication & Awareness

This policy is:

- Published on internal platforms and accessible to all personnel
- Communicated during onboarding and reinforced annually
- Supported by IAM awareness training (e.g., password security, phishing risks)
- Subject to mandatory annual acknowledgement

10. Policy Review & Continual Improvement

This policy is reviewed:

- Annually
- After major IAM incidents
- Following regulatory or technological changes
- Based on audit findings and management reviews

Reviews consider access controls, identity lifecycle processes, authentication mechanisms, emerging threats, and lessons learned.

CyberInfiniti Ltd is committed to continuously strengthening IAM practices to address evolving cybersecurity risks and business needs.

11. ALIGNMENT WITH ISO/IEC 27002:2022

Requirement	Covered in Section
Management approval	Document Control & Approval
Defined IAM objectives	Section 5
Assignment of IAM roles	Section 7
Commitment to IAM compliance	Section 6
Identity lifecycle management	Section 6.2

Authentication information management	Section 6.3
Access rights provisioning & revocation	Section 6.4, Section 8
Records and auditability	Section 6.6, Section 10
Continual improvement	Section 6.7, Section 12
Review at planned intervals	Section 8
Communication & acknowledgement	Section 9

12. Executive Statement

CyberInfiniti Ltd recognizes Identity and Access Management as a critical security control for protecting systems, data, and client trust. Through structured governance aligned with **ISO/IEC 27002:2022**, the organization ensures secure, accountable, and compliant access to all information assets while adapting to emerging threats and regulatory requirements.

1. PURPOSE

The purpose of this IAM Policy is to establish governance for the full lifecycle of identities and authentication information within Cyberinfiniti Ltd.
This policy ensures:

- Unique identification of individuals and systems accessing organizational assets.
- Appropriate assignment and revocation of access rights.
- Secure management of authentication information.
- Compliance with ISO/IEC 27002:2022, NDPA 2023, and contractual obligations.

---

2. ORGANIZATIONAL CONTEXT

Cyberinfiniti Ltd manages sensitive client data, vulnerability findings, and compliance documentation. Identity and access governance is critical to:

- Prevent unauthorized access.
- Maintain accountability for user actions.
- Protect confidentiality, integrity, and availability of assets

---

3. SCOPE

- This policy applies to:
- All employees, contractors, and consultants.
- All third-party service providers.
- All identities (human and non-human) accessing Cyberinfiniti systems.

- All authentication information (passwords, PINs, tokens, certificates)

---

4. DEFINITION OF IDENTITY AND ACCESS MANAGEMENT

Identity and Access Management (IAM) is defined as the governance and operational framework that ensures:

- **Unique Identification** – Every individual or system accessing Cyberinfiniti Ltd's assets must have a unique identity to maintain accountability.
- **Access Control** – Access rights are assigned based on business requirements, role responsibilities, and formal authorization.
- **Lifecycle Management** – Identities are created, maintained, modified, and revoked in a timely and controlled manner.
- **Authentication Security** – Authentication information must be securely allocated, transmitted, and managed.
- **Confidentiality** – Identities and authentication information must be protected against unauthorized disclosure.
- **Integrity** – Identity records and authentication data must remain accurate, complete, and tamper-proof.
- **Availability** – Authorized users must have reliable and timely access to systems and information necessary for their roles.

---

5. IDENTITY AND ACCESS MANAGEMENT OBJECTIVES

Cyberinfiniti Ltd establishes the following IAM objectives to ensure secure and accountable access to organizational assets:

- **Unique Identification** – Guarantee that each user or system has a distinct identity to maintain accountability.
- **Controlled Access Rights** – Assign, review, and revoke access rights based on business requirements, role responsibilities, and formal authorization.
- **Lifecycle Management** – Ensure timely creation, modification, and deactivation of identities when roles change or entities leave the organization.

- **Authentication Security** – Enforce strong authentication practices, including secure allocation, transmission, and storage of authentication information.
- **Compliance Assurance** – Align identity and access practices with ISO/IEC 27002:2022, NDPA 2023, and contractual obligations.
- **Auditability** – Maintain records of identity and authentication events to support investigations, audits, and regulatory compliance.
- **Resilience Against Threats** – Strengthen IAM processes to prevent unauthorized access, credential compromise, and insider misuse.
- **Continual Improvement** – Regularly review IAM practices to adapt to evolving business needs, regulatory changes, and emerging cyber threats.

---

6. POLICY STATEMENTS

In alignment with ISO/IEC 27002:2022 Controls 5.16 (Identity Management) and 5.17 (Authentication Information), Cyberinfiniti Ltd commits to the following IAM principles:

6.1 Governance Commitment

Top management shall provide visible leadership and support for IAM initiatives, ensuring accountability and compliance across the organization.

6.2 Identity Lifecycle Management

- Identities must be uniquely assigned to individuals or systems.
- Shared identities are prohibited unless explicitly approved and documented.
- Non-human identities (e.g., service accounts) require segregated approval and oversight.

- Identities must be promptly disabled or removed when no longer required.

6.3 Authentication Information Management

- Authentication information must be securely allocated, transmitted, and stored.
- Temporary credentials must be unique, non-guessable, and changed upon first use.
- Default vendor credentials must be changed immediately after installation.
- Strong password and authentication practices must be enforced in line with industry standards.

6.4 Risk-Based Access Control

Access rights shall be assigned, reviewed, and revoked based on business requirements, role responsibilities, and formal authorization.

6.5 Regulatory & Legal Compliance

IAM practices shall comply with applicable laws, including NDPA 2023, ISO/IEC 27002:2022, and contractual security requirements.

6.6 Records and Auditability

Records of identity lifecycle events and authentication information management shall be securely maintained to support accountability, investigations, and audits.

6.7 Continual Improvement

IAM processes shall be continuously reviewed and improved based on:

- Audit findings
- Risk assessments
- Security incidents
- Regulatory changes
- Management reviews

6.8 Exception Management

All IAM policy exceptions must:

- Be documented
- Undergo risk assessment
- Be approved by the CISO
- Be reviewed periodically

7. ROLES AND RESPONSIBILITIES

Role	Responsibility
Managing Director	Provides executive oversight, approves IAM policy, and ensures organizational commitment.
Chief Information Security Officer (CISO)	Owns IAM policy, defines strategic direction, and ensures compliance with ISO/IEC 27002:2022 and NDPA 2023.
GRC Manager	Develops IAM policy, monitors compliance, and coordinates audits and risk assessments.
SOC Manager	Enforces IAM controls operationally, monitors identity-related incidents, and reports anomalies.
IAM Specialist	Manages the full lifecycle of identities (creation, modification, revocation), oversees access rights, and ensures segregation of duties.
IT Operations Lead	Implements and secures authentication infrastructure, enforces password policies, and manages privileged accounts.
System Owners	Approve access requests for their systems, validate business justification, and ensure timely revocation of unused identities.
All Employees	Comply with IAM requirements, protect authentication information, and report suspected compromises immediately.
Third Party Services	Adhere to Cyberinfiniti's IAM requirements when accessing organizational systems and data.

8. POLICY REVIEW AND MAINTENANCE

This IAM policy shall be:

- **Reviewed annually** to ensure continued alignment with ISO/IEC 27002:2022 and NDPA 2023.
- **Reviewed upon significant changes** to business operations, technology platforms, or organizational structure.
- **Updated following major IAM incidents**, such as credential compromises, unauthorized access, or identity misuse.
- **Updated when regulatory requirements change**, including new data protection or cybersecurity laws.

The review process shall specifically consider:

- **Access Reviews** – Periodic verification of user access rights to ensure least privilege and timely revocation of unused identities.
- **Identity Lifecycle Audits** – Examination of identity creation, modification, and deactivation processes for compliance and accountability.
- **Authentication Control Evaluations** – Assessment of password policies, multi-factor authentication, and credential management practices.
- **Audit Findings** – Results from internal and external audits relating to IAM.
- **Management Review Outcomes** – Executive oversight of IAM effectiveness and risk posture.
- **Emerging Threat Landscape** – Adjustments to IAM practices based on evolving attack techniques (e.g., credential stuffing, phishing).
- **Lessons Learned from Incidents** – Incorporation of corrective actions and improvements following IAM-related security events.

---

9. COMMUNICATION & ACKNOWLEDGEMENT

This IAM policy shall be:

- **Published** on the internal governance portal and made accessible to all employees, contractors, and relevant third parties.
- **Communicated during onboarding** to ensure new personnel understand identity and access responsibilities from the outset.
- **Reinforced through annual IAM training**, covering topics such as:
    - Password hygiene and strong authentication practices.
    - Proper handling of authentication information (e.g., tokens, certificates).
    - Responsibilities for reporting compromised or suspicious credentials.
    - Awareness of risks associated with shared or non-human identities.
- **Supported by awareness campaigns** highlighting IAM best practices and emerging threats (e.g., phishing, credential stuffing).
- **Subject to mandatory annual acknowledgement**, requiring all employees and contractors to formally confirm their understanding and compliance with IAM requirements.

Failure to acknowledge or comply with IAM responsibilities may result in disciplinary action, contract termination, or legal consequences.

---

10. MONITORING & COMPLIANCE

Compliance with this IAM policy shall be monitored through:

- **Access Reviews** – Regular verification of user access rights to ensure least privilege and timely removal of unused identities.
- **Privileged Account Monitoring** – Continuous oversight of administrative and high-risk accounts to detect misuse or unauthorized escalation.
- **Authentication Audits** – Periodic evaluation of password strength, multi-factor authentication (MFA) adoption, and credential management practices.
- **Identity Lifecycle Audits** – Examination of identity creation, modification, and deactivation processes for compliance and accountability.
- **Incident Trend Reporting** – Analysis of IAM-related incidents such as credential compromises, unauthorized access attempts, or account misuse.
- **Risk Assessments** – Formal evaluation of IAM risks, including insider threats and third-party access exposures.
- **Executive Governance Reporting** – Regular updates to senior management on IAM compliance status, risks, and improvement initiatives.

Non-compliance consequences:

- Employees may face disciplinary action, up to and including termination.

- Contractors or third parties may face contract suspension or termination.
- Severe violations may result in regulatory reporting obligations and legal consequences.

---

11. ALIGNMENT WITH ISO/IEC 27002:2022

Requirement	Covered in Section
Management approval	Document Control & Approval
Defined IAM objectives	Section 5
Assignment of IAM roles	Section 7
Commitment to IAM compliance	Section 6
Identity lifecycle management	Section 6.2
Authentication information management	Section 6.3
Access rights provisioning & revocation	Section 6.4, Section 8
Records and auditability	Section 6.6, Section 10
Continual improvement	Section 6.7, Section 12
Review at planned intervals	Section 8
Communication & acknowledgement	Section 9

---

12. CONTINUAL IMPROVEMENT COMMITMENT

Cyberinfiniti Ltd commits to maintaining an effective Identity and Access Management (IAM) framework that evolves with:

- **Business growth** – Scaling IAM processes to support organizational expansion, new service offerings, and increased user identities.
- **Technological change** – Adopting advanced authentication technologies such as multi-factor authentication (MFA), biometrics, and passwordless solutions.
- **Regulatory development** – Ensuring IAM practices remain compliant with NDPA 2023 and future international data protection and cybersecurity standards.
- **Threat landscape evolution** – Strengthening IAM controls to defend against emerging attack techniques, including credential theft, phishing, and insider misuse.

This commitment ensures that IAM remains resilient, compliant, and aligned with Cyberinfiniti Ltd's strategic objectives and ISO/IEC 27002:2022 requirements

---